

(b) Guía Metodológica Detallada de la Encuesta APT

1. Objetivo de la encuesta

La encuesta tiene como objetivo medir el grado de madurez, preparación y resiliencia de las organizaciones frente a Amenazas Persistentes Avanzadas (APT), con especial foco en:

- Gobernanza y alineamiento con marcos normativos y de buenas prácticas (NIS2, NIST CSF, ISO 27001, MITRE ATT&CK, CCN-STIC, etc.).
- Gestión del riesgo APT, incluyendo la cuantificación económica y su integración en la continuidad de negocio.
- Indicadores y métricas operativas clave (MTTD, MTTR, MTTP, ratio de phishing, incidentes en la cadena de suministro, etc.).
- Capacidades de detección basadas en TTPs y marcos de inteligencia de amenazas.
- Capacidades de respuesta, recuperación, formación y cultura de seguridad.
- Inversión y medición de retorno (ROI) y de madurez (IGM).

2. Población objetivo y muestreo

- Población objetivo: organizaciones con actividad en España, tanto públicas como privadas, de sectores críticos y no críticos, que dispongan de algún tipo de función de TI o ciberseguridad.
- Unidad de análisis: la organización, representada por persona clave (CISO, CIO, CTO, responsable de riesgo, responsable de continuidad de negocio, etc.).
- Muestreo: se recomienda un muestreo estratificado por sector y tamaño, asegurando representación de:
 - Sector público (AGE, CCAA, EELL).
 - Sectores esenciales según NIS2 (energía, transporte, salud, finanzas, TIC, etc.).
 - Pymes de sectores no regulados, pero relevantes para la cadena de suministro.

3. Estructura de la encuesta

La encuesta se divide en diez bloques, cada uno orientado a un conjunto de dimensiones analíticas:

1. Perfil de la organización.
2. Gobernanza, estrategia y marco normativo.
3. Gestión del riesgo APT y métricas estratégicas.
4. Vectores de entrada: phishing, vulnerabilidades y cadena de suministro.
5. Detección basada en TTPs y MITRE ATT&CK.
6. Respuesta a incidentes y recuperación.
7. Formación, cultura y reporte.
8. Inversión, ROI e Índice Global de Madurez (IGM).
9. Colaboración, ejercicios conjuntos y lecciones aprendidas.
10. Visión de futuro.

Cada bloque contiene preguntas cerradas (elección simple o múltiple) y, en ocasiones, escalas de madurez (0–3) para poder construir índices agregados.

4. Escalas de medición

Se emplean principalmente tres tipos de escalas:

11. Escalas dicotómicas / selección múltiple: permiten clasificar prácticas y situaciones.
12. Escalas de madurez de 0 a 3:
13. 0 = No existe / no se utiliza / no se mide.
14. 1 = Existe de forma incipiente, informal o limitada.
15. 2 = Existe de forma sistemática pero con integración parcial.
16. 3 = Existe de forma sistemática, integrada y dirigida por objetivos.
17. Escalas ordinales (intervalos, rangos): para inversión (%), frecuencia, etc.

Estas escalas permiten el cálculo posterior de indicadores compuestos y de un Índice Global de Madurez (IGM) por bloque y global.

5. Cálculo del Índice Global de Madurez (IGM)

5.1. Definición

El IGM es un indicador sintético que resume el nivel de madurez de una organización frente a las APT, integrando múltiples dimensiones: gobernanza, riesgo, métricas, detección, respuesta, cultura e inversión.

5.2. Asignación de puntuaciones

Cada pregunta con escala de madurez (0–3) contribuye al IGM con su valor directo. Para preguntas categóricas, se asignan valores según un esquema predefinido. Por ejemplo:

- Estrategia formal de ciberseguridad (pregunta 6):
- Aprobada por el máximo órgano de gobierno: 3
- Aprobada a nivel de dirección intermedia: 2
- En elaboración: 1
- No formalizada: 0
- Integración del riesgo APT en la continuidad de negocio (pregunta 15):
- Totalmente integrado: 3
- Parcialmente integrado: 2
- Mencionado sin desarrollo: 1
- No integrado: 0
- No formalizada: 0

Integración del riesgo APT en la continuidad de negocio (pregunta 15):

5.3. Fórmula general

18. Cálculo de subíndices de bloque

Para cada bloque b , se calcula un subíndice IGM_b como:

$$\text{IGM}_b = (\text{Suma de puntuaciones de preguntas del bloque}) / (\text{Número de preguntas puntuables del bloque} * 3)$$

El resultado está entre 0 y 1.

19. Cálculo del IGM global

El IGM global puede calcularse como media ponderada de los subíndices de bloque:

$$\text{IGM}_{\text{global}} = \sum (\text{IGM}_b * w_b)$$

Donde w_b son los pesos para cada bloque (por defecto, iguales; opcionalmente, se puede dar más peso a detección y respuesta).

5.4. Interpretación

- 0,00–0,25: Madurez inicial / reactiva.
- 0,26–0,50: Madurez básica / en desarrollo.
- 0,51–0,75: Madurez intermedia / gestionada.
- 0,76–1,00: Madurez avanzada / optimizada.

6. Cálculo del ROI de ciberseguridad

6.1. Planteamiento

El ROI (Return on Investment) en ciberseguridad se puede aproximar relacionando:

- Las inversiones realizadas en controles de seguridad.
- La reducción en pérdidas esperadas (por incidentes evitados o mitigados).

6.2. Variables básicas

- INV: Inversión anual en ciberseguridad.
- PLA_0: Pérdida esperada anual antes de las mejoras (baseline), estimada a partir de incidentes históricos o benchmarks.
- PLA_1: Pérdida esperada anual después de las mejoras.

6.3. Fórmula simplificada de ROI

$$\text{ROI}_{\text{ciber}} = (\text{PLA}_0 - \text{PLA}_1 - \text{INV}) / \text{INV}$$

- ROI > 0 indica que las pérdidas evitadas compensan la inversión.
- ROI < 0 indica que las pérdidas evitadas no compensan (al menos en el horizonte considerado).

6.4. Relación entre IGM y ROI

Aunque el IGM no es una medida financiera, se pueden explorar correlaciones entre:

- IGM_bloques (especialmente detección, respuesta y gestión de vulnerabilidades).
- Frecuencia e impacto de incidentes.

La plantilla de Excel propuesta permitirá almacenar respuestas, calcular puntuaciones y experimentar con escenarios de ROI.

7. Consideraciones éticas y de confidencialidad

- Los datos recogidos deben anonimizarse antes de cualquier análisis agregado.
- Se recomienda firmar acuerdos de confidencialidad (NDA) con las organizaciones participantes cuando los resultados puedan exponer debilidades sensibles.
- Los resultados se presentarán de forma agregada (por sector, tamaño, etc.), evitando la identificación de organizaciones concretas.

8. Uso de los resultados

Los resultados pueden utilizarse para:

- Informar a los órganos de gobierno sobre el estado real de madurez frente a APT.
- Priorizar inversiones y proyectos de mejora.
- Medir la evolución en el tiempo (ediciones periódicas de la encuesta).
- Comparar la situación de una organización con referencias sectoriales o nacionales.

En definitiva, la encuesta pretende convertir el ruido habitual en el discurso de ciberseguridad en métricas comparables, y si de paso ayuda a justificar presupuestos sin dramas, mejor.